



By Nitesh Singh

Job Ready Free Live Training To Become A

SOC

Analyst L1 For Free

Defronix Cyber Security → <https://defronix.com>

01

Core Concept

TTPs (Tactics, Techniques, and Procedures) in SOC

They describe how attackers think, act, and operate during a cyber attack.

*If an IOC tells you what happened,
TTPs tell you how and why it happened.*

SOC analysts use TTPs to:

- Detect attacks even when IOCs change
- Understand attacker intent
- Build better detections, alerts, and response playbooks

CYBER KILL CHAIN VS. MITRE ATT&CK





Why TTPs Important in a SOC

Imagine this real-world example :

IOC ->> “A masked person was seen”

TTP ->> “The attacker broke the lock, entered through the back door, disabled CCTV, and escaped via the fire exit”

SOC teams care more about behavior than just indicators.



TACTICS – The Goal

Tactics describe WHY the attacker is doing something :

Each tactic represents a phase of the attack lifecycle.

Common attacker goals:

- Gain initial access
- Steal credentials
- Move laterally
- Exfiltrate data
- Maintain persistence



TACTICS – Example

Tactic	Meaning
Initial Access	How attacker first gets in
Execution	Running malicious code
Persistence	Staying in the system
Privilege Escalation	Becoming admin
Defense Evasion	Avoiding antivirus/EDR
Credential Access	Stealing passwords
Lateral Movement	Moving to other systems
Exfiltration	Stealing data



TECHNIQUES – The Method

Techniques describe *HOW* the attacker achieves a tactic

Think of techniques as **specific attack methods**.

For Example :

Tactic: Credential Access

Techniques:

- Keylogging
- Credential dumping (LSASS)
- Browser password theft
- Phishing for credentials

Each tactic has **multiple techniques**.



PROCEDURES – The Exact Steps

Procedures are the attacker's exact implementation in the real world

This is where:

- Tools
- Commands
- Scripts
- Timing etc come into play.

Example

Technique: Credential Dumping

Procedure Command Example :

```
procdump.exe -accepteula -ma lsass.exe lsass.dmp
```

Most SOC teams map TTPs using:

MITRE ATT&CK :

It is a -

- A global knowledge base
- Used by SOC's, SIEMs, EDRs, XDRs
- Built around Tactics & Techniques

Every SOC analyst must know MITRE ATT&CK.



IOCs = Indicators of Compromise

They are observable evidence that suggests a system may be compromised or under attack.

If TTPs describe attacker behavior, IOCs are the footprints attackers leave behind.

SOC analysts hunt, detect, correlate, and respond using IOCs every single day.

IOC = “Something bad happened here, and we can prove it with data.”

That “data” comes from:

- Logs
- Network traffic
- Endpoint activity
- Email headers
- File systems

In a real SOC environment, IOCs help you:

- Trigger alerts in SIEM
- Confirm malicious activity
- Correlate attacks across systems
- Respond quickly (block, isolate, contain)
- Write incident reports



Types of IOCs - Network Based IOCs

These show what happened inside the system.

Examples :

- Malicious IP address
- Suspicious domain
- C2 server communication
- Unusual ports or protocols

Where SOC Sees Them

- Firewall logs
- Proxy logs
- DNS logs
- IDS/IPS alerts



Host / Endpoint-based IOCs

These show what happened inside the system.

Examples :

- Suspicious processes
- Unexpected services
- Registry changes
- New scheduled tasks

Where SOC Sees Them

- EDR/XDR
- Windows Event Logs
- Sysmon
- Linux audit logs



File-based IOCs

These relate to malicious files.

Examples :

- File hash (MD5, SHA256)
- File name patterns
- File size anomalies

Where SOC Sees Them

- Antivirus
- EDR
- Email security gateways
- Sandboxes



Email-based IOCs

These relate to malicious emails.

Examples :

- Malicious sender email
- Phishing subject lines
- Malicious URLs
- Header anomalies

Where SOC Sees Them

- Email security tools
- Microsoft Defender
- Proofpoint / Mimecast
- User reports



IOC Confidence Levels

All IOCs are not equal at all.

Confidence	Example
Low	Single suspicious IP
Medium	Known phishing domain
High	Malware hash + execution
Very High	Multiple correlated IOCs

SOC analysts never rely on a single IOC.



IOCs vs TTPs

IOCs	TTPs
Evidence	Behavior
What happened	How it happened
Short-lived	Long-lived
Easy to change	Hard to change
Used for alerts	Used for detection logic

Professional SOC's use BOTH together.



IOC → Alert → Investigation (Real
SOC Flow)

1. IOC detected (IP / hash / process)
2. SIEM generates alert
3. SOC L1 validates IOC
4. SOC maps to TTP
5. Decision: True Positive or False Positive
6. Escalation or closure



Alert Triage

Alert Triage is the structured process of:

Quickly analyzing security alerts to decide whether they are real threats, false alarms, or need escalation.

In simple words:

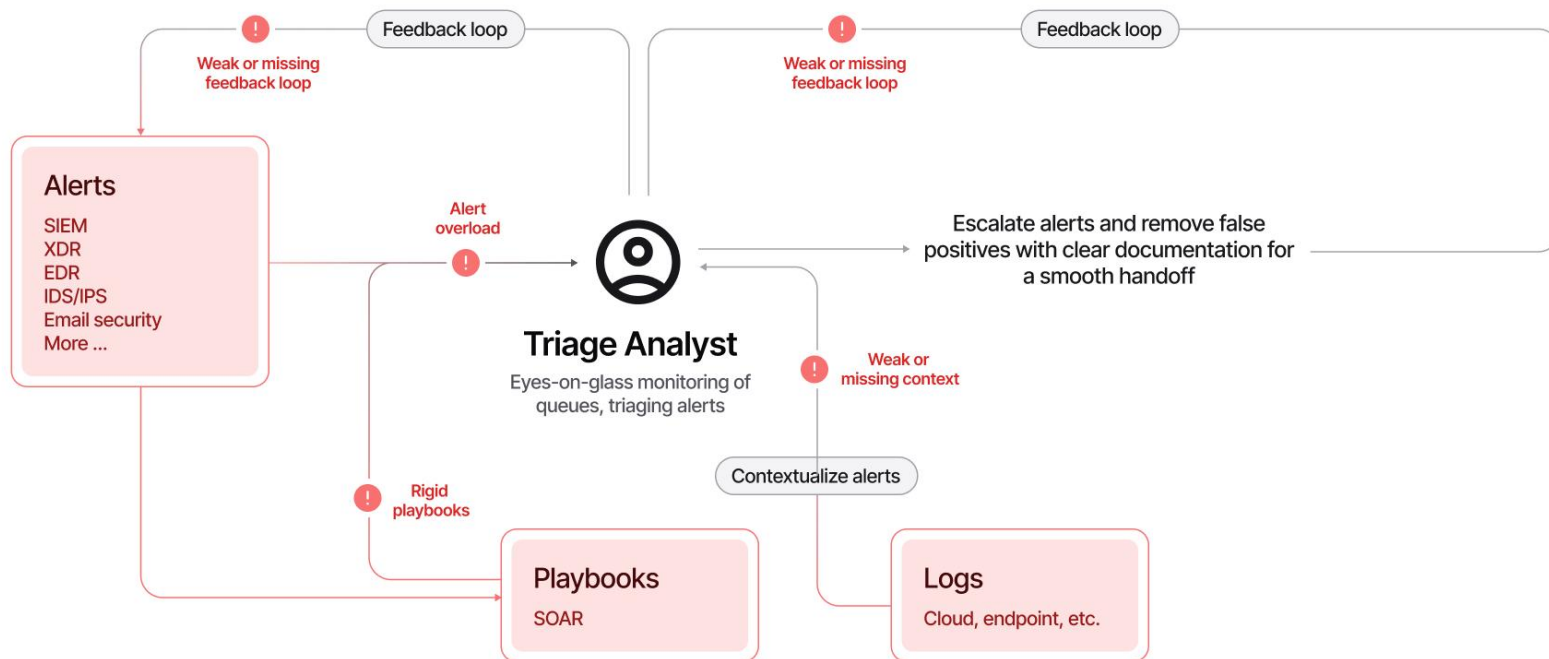
Alert triage = separating real attacks from noise, fast and accurately

SOC environments generate **thousands of alerts daily**. Only a **small percentage are real incidents**. Your job as a SOC analyst is to **filter, prioritize, and act**.

First, an event must occur, like user login, process launch, or file download. Then, the system, like your OS, a firewall, or a cloud provider must log the event. After that, all system logs must be shipped to a security solution like SIEM or EDR. The SOC team can receive millions of logs per day from thousands of different systems, where most of the events are expected, but some require attention. Alert, a notification generated by a security solution when a specific event or sequence of events occurs, is what saves SOC analysts from manual log review by highlighting only suspicious, anomalous events. With alerts, analysts triage just dozens of alerts per day instead of millions of raw logs.



Alert Triage





Why Alert Triage Is Critical

Without proper triage:

- SOC teams drown in alerts
- Real attacks get missed
- Response is delayed
- Business impact increases

SOC analysts are promoted based on triage quality, not number of alerts closed.

Triage decides whether an alert becomes an incident

With good triage:

- False positives are reduced
- Real threats are caught early
- SOC becomes efficient and trusted



18

Core Concept

Alert Properties

Property	Meaning (SOC L1)	Example
Alert Time	When the alert was generated	<i>Mar 21, 15:35</i>
Alert Name	Summary of what triggered	<i>Unusual Login Location</i>
Alert Severity	Urgency assigned by detection	<i>Low / Medium / High / Critical</i>
Alert Status	Current lifecycle state	<i>New / In Progress / Closed</i>
Alert Verdict	L1 classification outcome	<i>True Positive / False Positive</i>
Alert Assignee	Analyst handling the alert	<i>Assigned Analyst Name</i>
Alert Description	Explanation of what the alert means	<i>Detailed description of the suspicious activity</i>
Alert Fields	Contextual values that led to the alert	<i>Affected Hostname, Entered Commandline, etc.</i>

Source : tyhackme.com



Alert Prioritisation

The process of deciding which “Alert” to take is called Alert Prioritisation.

Every SOC team decides on its own prioritisation rules and usually automates them by setting the appropriate alert sorting logic in SIEM or EDR

1. **Filter the alerts**

Make sure you don't take the alert that other analysts have already reviewed, or that is already being investigated by one of your teammates. You should only take new, yet unseen and unresolved alerts.

2. **Sort by severity**

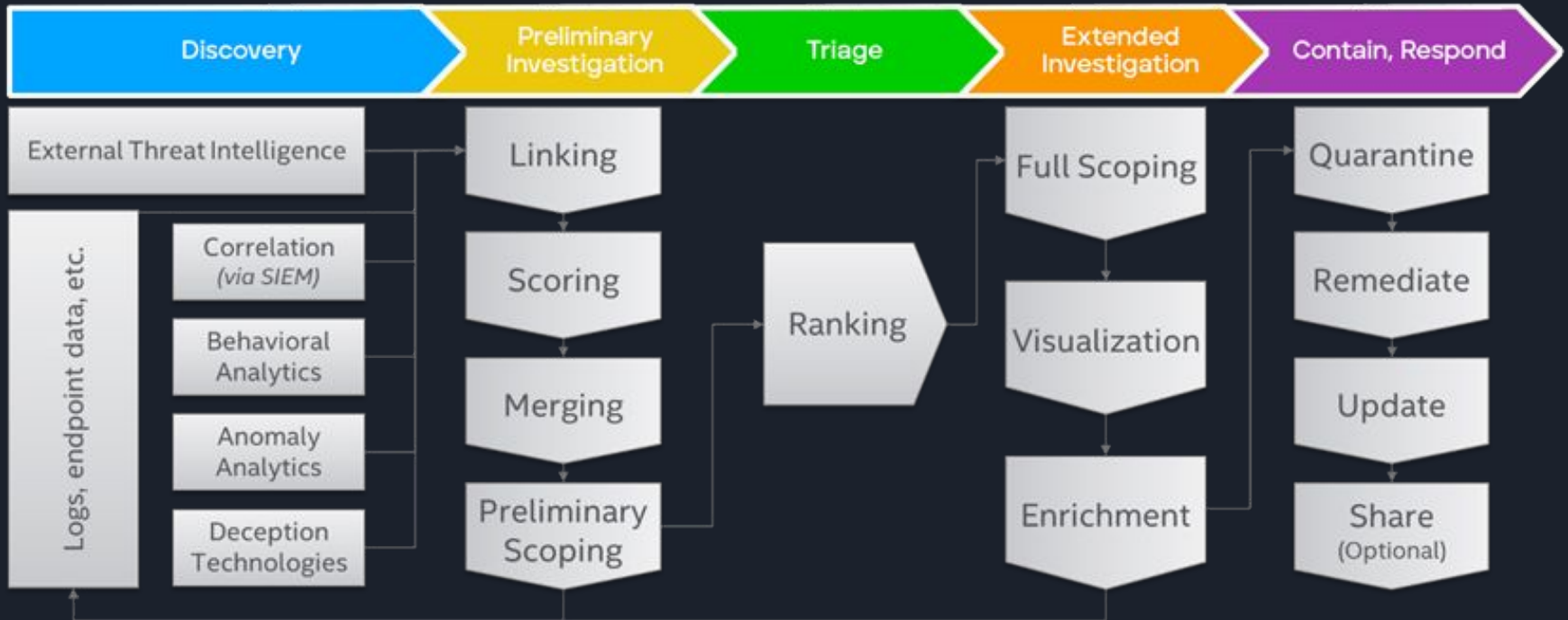
Start with critical alerts, then high, medium, and finally low. This is because detection engineers design rules so that critical alerts are much more likely to be real, major threats and cause much more impact than medium or low ones.

3. **Sort by time**

Start with the oldest alerts and end with the newest ones. The idea is that if both alerts are about two breaches, the hacker from the older breach is likely already dumping your data, while the "newcomer" has just started the discovery.



Alerts





Alerts Triaging

Initial Actions :

The initial steps are designed to ensure that you take ownership of the assigned alert and avoid interfering with alerts being handled by other analysts, and confirm that you are fully prepared to proceed with the detailed investigation. You achieve it by first assigning the alert to yourself, moving it to In Progress, and then familiarising yourself with the alert details like its name, description, and key indicators.



Alerts Triaging

Investigation :

This is the most complex step, requiring you to apply your technical knowledge and experience to understand the activity and properly analyse its legitimacy in SIEM or EDR logs. To support L1 analysts with this step, some teams develop Workbooks (also known as playbooks or runbooks) - instructions on how to investigate the specific category of alerts. If workbooks are not available, below are some key recommendations:

- Understand who is under threat, like the affected user, hostname, cloud, network, or website
- Note the action described in the alert, like whether it was a suspicious login, malware, or phishing
- Review surrounding events, looking for suspicious actions shortly after or before the alert
- Use threat intelligence platforms or other available resources to verify your thoughts